

Security Threats of a Blockchain-Based Platform for Industry Ecosystems in the Cloud

Philipp Ruf*, Jan Stodt*, Christoph Reich*

*Institute for Data Science, Cloud Computing and IT-Security (IDACUS) –
Furtwangen University of Applied Science, Furtwangen, Germany
Email: {philipp.ruf, jan.stodt, christoph.reich}@hs-furtwangen.de

Abstract—In modern industrial production lines, the integration and interconnection of various different manufacturing components, like robots, laser cutting machines, milling machines, CNC-machines, etc. allows for a higher degree of autonomous production on the shop floor. Manufacturers of these increasingly complex machines are beginning to equip their business models with bidirectional data flows to other factories. This is creating a digital, cross-company shop floor infrastructure where the transfer of information is controlled by digital contracts. To establish a trusted ecosystem, the new technology “blockchain” and a variety of technology stacks must be combined while ensuring security. Such blockchain-based frameworks enable bidirectional trust across all contract partners. Essential data flows are defined by specific technical representation of contract agreements and executed through smart contracts.

This work describes a platform for rapid cross-company business model instantiation based on blockchain for establishing trust between the enterprises. It focuses on selected security aspects of the deployment- and configuration processes applied by the industrial ecosystem. A threat analysis of the platform shows the critical security risks. Based on an industrial dynamic machine leasing use case, a risk assessment and security analysis of the key platform components is carried out.

Keywords: *IoT, Security, Cross Company Business Model, AI, Blockchain, Cloud, Risk Analysis*

I. INTRODUCTION

WITH the 4th industrial revolution, machines can increasingly be integrated into a digital production facility of companies, which opens up novel business opportunities. The continuous recording of machine utilization, e.g. production and process data, enables billing models such as currently existing static leasing rates for machines to be replaced by dynamic pay-as-use models. A basic requirement for such business model is that trust exists between all companies involved. Another aspect is, that in the event of disputes, accountability modules must have persisted evidence of triggering events, responsible actors respectively. Another aspect to a cross-company business model is the identity management, where operations involving Personally Identifiable Information (PII)s must comply with the applicable law. The Collaborative Smart Contracting Platform for digital value-added Networks (KOSMoS) platform is a Blockchain (BC)-based framework for rapid development and execution of cross-company business models, simplifying the setup and management of software components of such an ecosystem to increase trust. The main functionality of such a platform is tamper-proofing of audit trails and securing contract terms

and executions implemented as smart contracts. While the BC itself must be generally secure, the security requirements for the broad KOSMoS ecosystem which feeds the BC and configures and deploys the business-backing technologies are even more critical, since recorded data is the foundation of trust within the BC. This work focuses on selected security aspects of the deployment- and configuration processes applied by the KOSMoS platform. With discussing related work in section II, basic security aspects relevant to the KOSMoS platform as described in Section III become clearer. With the depiction of deployment processes regarding contract-related technology stacks in Section IV, the basis for illustrating selected platform security aspects in Section V is given. The work is concluded in Section VI.

II. RELATED WORK

Since the BC-based platform is implemented in the cloud, cloud security threats must be considered. In order to establishing trust in the overall system, every BC-preceding platform modules are required to be held accountable for outgoing communication. Although similarities with the fundamental BC- and Internet of Things (IoT) aspect of the KOSMoS platform can be found in various writings, the authors often did not focus on the surrounding ecosystem, their impact on security respectively. As the BC enables trust in cross-company business, the chain of accountability across the whole system must be considered. Therefore, we look at related work in cloud security, BC, and industrial IoT.

A. Cloud-based Blockchain & Smart Contract Security

Various threats related to cloud computing were depicted by Bharadwaj et al. in [1]. With respect to Content Delivery Network (CDN), Jalalpur et al. proposed a dynamic security orchestration system in [2], where security function chains are managed and deployed according to recognized malicious system behaviour. Recent papers provide a comprehensive survey of BC, how BC works, security analysis of BC, and privacy threats to BC [3]–[6]. The work of Wang et al. [7] focuses on the well-known forking attack, where divergent BCs are generated to insert some new features, e.g., data blocks, that facilitate security breaches. Although most of the work in this area focuses on detecting attacks in real-time transactions, Wang developed a large deviation theory to study the vulnerability of BC networks created by intentional forks

from a micro perspective, promoting predictive and strategic planning mechanisms to defend against the forking attack. Another problem is the Block WithHolding (BWH) attack in a BC network. In the paper of Tosh et al. [8], various pool reward mechanisms are considered to mitigate BWH. The BWH attack provides abundant resources to rogue miners in the BC cloud to disrupt the mining efforts of honest miners, which have been verified through simulations. In addition to the threats that directly impact the BC for business, it is important to focus on the smart contracts that are provided with the BC. A survey of BC smart contract security review [9] proposed a taxonomy on the topic of smart contract security review and discussed the advantages and disadvantages of each category of listed studies. Yamashita et al. describes a number of risks that can occur in the smart contract domain with Hyperledger Fabric [10]. Risks can be categorized as "non-determinism", "state database", "fabric specification" and "common practices". In response, the developers developed a scanner tool to highlight the known error sources to a developer. A wide range of Distributed Control System (DCS)-enabling applications, modeling processes, and the work of management and control approaches were discussed. The security threats of smart contracts were analyzed by Kim et al. in [11], where the vulnerabilities were divided into three categories: static analysis for vulnerability detection, static analysis for program correctness and dynamic analysis. Tikhomirov et al. [12] provides a comprehensive classification of code issues in Solidity and implemented *SmartCheck* - an extensible static analysis tool that detects vulnerabilities of smart contracts. The implementation of *SmartCheck* translates the Solidity source code into an XML-based intermediate representation and checks it against XML Path Language (XPath) patterns. By installing malicious chaincode, e.g. the smart contract logic, on an controlled *Hyperledger* BC node, an artificial attack environment can be generated, as described by Li et al. in [13]. The main threats of clouds and BC-based smart contracts are considered for the described use case of this paper.

B. Industrial Internet of Things Security

In reviewing existing work on IoT security, it can be seen that many authors present a taxonomy of security threats, attacks, or challenges and discuss possible mitigation. A number of research papers were selected as relevant to this study and presented in this section. A BC-based IoT sensor data logging and monitoring system was implemented by Lockl et al. in [14], where expert-interviews helped in identifying different design principles for such a platform. The mentioned Ethereum-based prototype improves data integrity and availability, operating costs were not taken into consideration. Basic architectural tactics for creating BC-based IoT platforms were surveyed by Yáñez et al. in [15]. The contribution of Haddad-Pajouh et al. [16] is the classification of potential IoT security threat and challenges by a general IoT architectural view. Furthermore IoT security challenges and solutions are grouped by the layered architecture to mitigate security threats. The

paper by Khan et al. [17] outlines the security requirements for IoT along with the existing attacks and threats and discusses mitigation solutions with BC. BC can mitigate security threats by providing global unique identifiers, data authentication, data integrity, device authentication, device authorization, device privacy, and secure communication [17]. General threats and attack vectors on IoT are described by Jurcut et al. in [18]. Solutions to address compromised security are presented, as well as methods to mitigate risk with prevention and potential security mitigation through the use of BC. The security of DCSs was surveyed by Ali et al. with focus on Cyber Physical System (CPS) in [19]. A methodology for creating privacy thread models with respect to IoT was presented by Jain et al. in [20]. Identifying and classifying information in the IoT system according to its sensitivity, representing it in a common model, and then applying a proposed privacy risk map supports system engineers to verify the implementation of privacy-friendly measures. A framework for the investigation of IoT system security was defined by Mohsin et al. in [21]. In providing a formal specification for IoT behavior, a domain-specific device configuration is modeled. Threats are classified by the device context, triggers and actuation. The security in CPS was surveyed by Humayed et al. in [22]. A basic distinguishing between criminal-, financial-, political-, privacy- and physical threats, a variety of impacts on CPS security are derived. Also, various threats to specific scenarios, e.g. Industrial Control Systems (ICS), smart grid, medical devices and smart cars, have been studied in detail. Techniques regarding the protection against sensor attacks in CPS were outlined by Marquis et al. in [23]. The applied combination of watermarking and resilience filtering techniques can enhance confidence in cross-company business model frameworks in general, because of the enhanced accountability. Various existing and future security threats to IoT were surveyed by Restuccia et al. in [24]. Focusing on security by design for the entire system, Software Defined Networking (SDN), proposed attack detection and mitigation techniques using Machine Learning (ML), and the polymorphic infrastructure of IoT, the authors offered a roadmap with specific research questions. Focusing on supply chains, Dasari et al. proposed a framework for detecting compromised components in IoT infrastructure in [25]. Installing a *birth certificate*, which contains additional information about the components used in a product, a Trusted Platform Module (TPM), allows comparing the extracted run time information and detecting compromised modules. Aspects of the design of critical infrastructure nodes in IoT were proposed by Mcginthy et al. in [26]. Different security levels are designed based on selected features such as memory protection, encryption or strength of message validation, applied algorithms respectively. The impact of ransomware threats in Supervisory control and data acquisition (SCADA) systems was outlined by Butt et al. in [27]. Various real world attacks and applied methods are described, and recommendations and defense strategies are discussed.

III. CROSS-COMPANY TRUSTABLE ECOSYSTEMS

In order to accelerate cross-company business, a platform is defined to support logging and control of cross-company data flow using instantiated KOSMoS-Contract templates representing different use cases, as for example the one provided in section V-E. This section describes such a platform, the KOSMoS platform, developed by a consortium of academia and industry to implement cross-company use cases such as dynamic industrial machinery leasing. The KOSMoS platform essentially consists of two main components: a) a singular global KOSMoS-Contract management instance, hereafter referred to as the KOSMoS Cloud, and b) a set of customer-facing KOSMoS on-premise environments which are responsible for executing associated contracts. The main

of data handling processes throughout contract partners. With the digital representation of an agreed business contract, the global component of the platform needs to be able to identify each participating identity. Assuming that the identity management solution of the participating organizations is directory-based, as for example Lightweight Directory Access Protocol (LDAP), the *Keycloak* [29] technology is able to connect different identities within a novel cross-company realm. Analogous to a hand-signed business contract, a digital KOSMoS Contract must be approved by each party involved. Therefore, a self-service web application which is also configured to recognize the associated *Keycloak* users, serves as a central KOSMoS contract definition and activation endpoint.

B. KOSMoS On-Premise

Just as its global counterpart, an KOSMoS on-premise infrastructure relies on a container engine, too. By using specific technologies whose container image tags are defined within a KOSMoS Contract, a highly generic and verifiable ecosystem is created. While a particular scenario requires a dedicated module implementation, commonly infrastructural support containers interpreting their respective parameters are vital to the dynamics of the system. Proven technologies were chosen throughout the whole system to verify message integrity, its confidentiality and system authentication. Another design decision was to implement authorization mechanisms within each container where the group and role membership associated by *Keycloak* are verified. This way, there is no need to certify specific modules inside a central authorization system whenever modifications to a container are necessary. The trade-off to this approach is an implied audit of containers before making them usable by KOSMoS. However, the software module that has the most to do with the KOSMoS-Contract execution is the on-premise connection with the workshop machine itself. Since this part most likely depends on specific machine protocols like *OPC-UA*, its implementation is abstracted by also highly configurable *machine-connector* container images. For the KOSMoS on-premise communications, certificate-based authentication is enabled by integrating the BC-enabled Certificate Authority (CA) with a locally executed secret store, namely *Vault* [30].

C. Additional Components

When integrating a third party in a KOSMoS Contract, new security and privacy challenges arise. There are KOSMoS demonstration use cases where dedicated ML models are created and refined by an external organization. One example is to support the unification of ML-based *Predictive Maintenance* with the BC-based financial billing by applying the KOSMoS platform. The customer's application of and compliance with the model in turn affects billing to the manufacturer. By transmitting relevant production data-sets, a KOSMoS customer, as well as the provider, is obviously bound to trust this foreign actor and the served results. Regardless of whether an ML model is to be applied within the KOSMoS-On-Premise infrastructure or by an external service-based implementation,

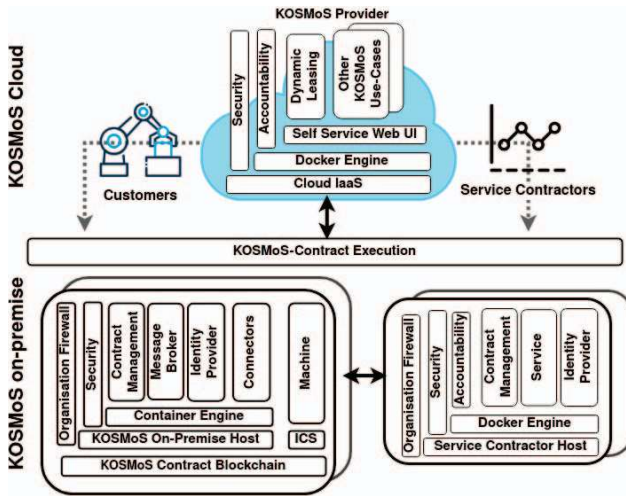


Fig. 1. KOSMoS Ecosystem Layers

subcomponents of the KOSMoS platform are shown in Figure 1, details of the security aspects present are discussed below.

A. KOSMoS Cloud

Every function carried out by the customers KOSMoS on-premise system, a foreign contractors KOSMoS environment respectively, is configured by a self-service contract management interface served by the KOSMoS Cloud. To support the dynamic provision of highly configurable technology stacks, a container-based solution was chosen where implemented KOSMoS modules are registered in a globally reachable *Harbor* [28] container registry. By integrating identity management, which is also applied globally, into this registry, tenant-specific authorizations can be set for containers that are tailored to the individual needs of a contract partner. The respective KOSMoS-Contract templates define parameters required to configure the technology stack with the specific use case execution environment. Updating module versions is feasible via changing the dedicated container tag. Since changes to modules may impact the overall ecosystem of already active contract partners, defining a new KOSMoS-Contract and deactivating its predecessor guarantees integrity

adversarial ML attacks may occur [31]. Since potentially any third-party system can be integrated into this framework, security concerns are always domain-specific.

IV. ECOSYSTEM THREAT ANALYSIS

The threat analysis of the entire ecosystem was reduced to the on-premise part in order to stay in scope. It is assumed that the connection to KOSMoS Cloud is encrypted and the identities are verified by certificates. Especially the setup of a new KOSMoS Contract instantiation is critical and therefore some aspects of the whole deployment process are shown in Figure 2. For the sake of clarity and comprehensibility, we

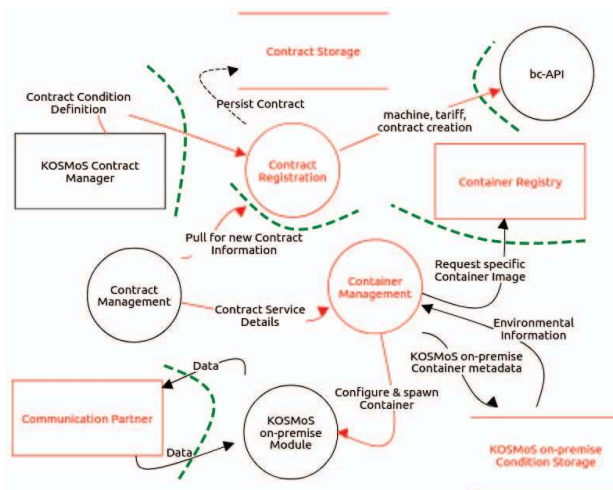


Fig. 2. Threats to the Deployment of a KOSMoS on-premise Infrastructure

have omitted the visualization of interactions with KOSMoS modules irrelevant to the deployment process, as well as the identity management within the threat model. A basic implementation of the on-premise system according to a previously instantiated KOSMoS-Contract BC-channel is implied. After a STRIDE analysis, several threats were identified which are partially discussed in the following:

DOS of the KOSMoS Cloud platform: A global KOSMoS platform is executed within a cloud-based environment where the *Contract Registration* process and a system-wide *Container Registry* are inherently vulnerable to Denial of Service (DOS) attacks. When such an attack occurs, already activated contract infrastructures can cache relevant messages until reachability to the respective counterpart is restored.

Tampering of the global contract store: The KOSMoS Cloud service is periodically pulled for new KOSMoS-Contract objects by the *Contract Management* process, which includes the customer's infrastructure configuration. When manipulating entries within the global *Contract Storage*, malicious situations at the KOSMoS on-premise are likely. If a customer can be tricked into pulling a purported KOSMoS module by manipulating the tags of the specific container required for the contract, arbitrary software can be run. When manipulating

entries within the global *Contract Storage*, malicious situations at KOSMoS on-premise are likely.

Spoofing the registration: Spoofing the *Contract Registration* endpoint and provoking an interaction with an KOSMoS on-premise environment cannot rule out gaining insights into the victim's contract activities or preparing further malicious actions.

Elevation of Privilege of the condition store: The edge technology stack management system is the most critical part of an KOSMoS on-premise setup, as contract-specific parameters are dynamically applied to the dedicated containerized environments. If, for example, the *Edge Condition Storage* is accessed by a random actor, unauthorized information acquisition about a customer's infrastructure is to be suspected. With insights into ports used, container configuration, host and firewall rules, mounted points, and operational events, a malicious actor is able to aggregate this information to attack the shop floor in the most effective way.

Spoofing the identity: By getting a customer to communicate with a *Communication Partner* that is foreign to the KOSMoS on-premise environment and its contract specification, a variety of undesirable events ranging from information disclosure to code injection are possible, depending on implemented countermeasures. By recording the communications' metadata of a customer network, the goal is to gain insight into disclosed business statistics.

Information Disclosure: All data flows shown in Figure 2 are privacy-sensitive and must be encrypted connections.

V. SECURITY EXPOSURES

Even with standard security mechanisms, an KOSMoS infrastructure is still vulnerable to a variety of malicious techniques. Since a broad and detailed discussion of attack vectors is out of scope, the following Sections V-A, V-B, V-C, and V-D provide a partial overview of platform security risks and their impact on the ecosystem. Selected threats are concluded in table V. The aspects shown are discussed in more detail in the Section V-E, which presents a risk assessment of a real-world scenario in terms of technical attacks, human factors and attacks on business processes. A critical issue in realizing cross-company use cases is gathering information about publicly available data from the web, passive sniffing, common vulnerabilities and exposures, among others. Gaining insight into a service stack not only simplifies the preparation of further malicious actions, but can also provide clues to current business workloads and the value of an attack. For an illustration of various maliciously applicable techniques for a system like KOSMoS, reference is also made to the *MITRE ATT&CK* catalog [32], which is often used as foundation for the creation of specific threat models, as for example in [33]–[35].

A. Infrastructure Exposures

Cloud Infrastructure Information: With a focus on building system-specific attack trees, probing accessible KOSMoS

TABLE I
RISK MATRIX

Exposure	Threat	Impact	Risk	Vulnerability	Mitigation
Infrastructure	Cloud Infrastructure Information Discovery	Low	Middle	Low	User account management, least privilege, periodic audits
	Public Facing Applications	Critical	Low	Low	Firewall, access policies configured carefully
	Patch Deficit	Critical	Middle	Probable	Continuous patch management
	Denial of Service	Middle	Middle	-	Firewall, DDoS protection services
	Malware	Critical	Middle	Probable	Malware detection, awareness training
	SCADA System Attack	Critical	Middle	Probable	Least privilege, periodic audits, network segmentation
Human	Social Engineering	Critical	Critical	Probable	Awareness training, behavior anomaly detection, least privilege
	Identity Spoofing	Critical	Critical	Low	2 factor authentication, identity fraud detection, physical key cards
	Misconfiguration	Critical	Critical	Low	4-eyes configuration, periodic audits, config file validation
Business	Faulty Defined KOSMoS Contract Template	Critical	Low	Low	Carefully defined templates by experts
	Service Provider Manipulates Data	Critical	Low	Low	Audit data collector securely connected to blockchain
	Error in Data Collection	Probable	Low	-	Monitoring, anomaly detection
	Contract Manipulation	Critical	Low	-	Blockchain nodes must have consensus for contract changes
Use Case (Infrastructure Specific)	Denial of Service	Low	Low	-	Data caching on premise
	Malware	Middle	Middle	Probable	Malware detection, awareness training
	Application Disguising	Critical	Low	Low	Audit container image before publishing
	Man in the Middle	Critical	Low	Probable	Message encryption and authentication (certification)
	Non Compliance	Critical	Low	Low	Anonymization
	Edge Misconfiguration	Critical	Middle	-	4-eyes configuration, periodic audits, config file validation
Use Case (Human Specific)	Social Engineering	Critical	Low	Probable	Awareness training, behaviour anomaly detection, least privilege
	Identity Spoofing	Critical	Low	Low	2 factor authentication, identity fraud detection, physical key cards
	Inside Attacker	Critical	Middle	-	Intrusion detection system, network segmentation, least privilege
Use Case (Business Specific)	Sensor Data Manipulation	Middle	Low	-	Monitoring, anomaly detection
	Smart Contract Manipulation	Critical	Low	Low	Blockchain nodes must have consensus for contract changes
	Machine Usage Data Manipulation	Middle	Middle	-	Periodic audit, data caching, anomaly detection
Smart Contract	Non-Determinism	Middle	Middle	Low	Smart contract scanner, programming specific linting tools, Hyperledger Fabric architecture
	External Stateful Services	Critical	Middle	Low	Blockchain oracle that acts as intermediary / caching
	Input Validation / Error Handling	Critical	Middle	Probable	Input validation, strict error handling / safe error behaviour

Cloud resources can be fatal, especially in hybrid cloud environments (T1580 [32]).

Public Facing Applications: In the context of cloud infrastructure discovery, publicly available applications, regardless of where they physically run, can attract unwanted attention (T1190 [32]) [36]. Unexpected system behavior can be caused by the misuse of poorly secured internet-facing applied services. Depending on the module, the entire underlying infrastructure may also be affected.

Patch Deficit: Since the generic KOSMoS technology stack distribution system allows integration of various services, dedicated security patches must be ruthlessly applied to each module [22]. Since every KOSMoS component depends on containerization in one way or another, an attacker could also

try to target obsolete base-image versions of container definitions for which novel exploits now exist. The module most vulnerable to this type of action is the provider's KOSMoS-Contract management platform, which is public reachable.

Denial of Service: Another common infrastructure threat relates to DOS attacks, where compromising or preventing the availability of an application's ability to serve can severely impact entire organizations (T1499 [22], [32]). Taking into account the knowledge of victims' compensation and prevention systems highly specialized DOS attacks can still be carried out through physical interventions such as power shutdown or manipulation of system-dependent services. A KOSMoS provider's infrastructure may be constrained due to BC cloud accessibility issues while previously activated

KOSMoS-Contracts are autonomously executed at the customer's shop floor. Any publicly available KOSMoS module as well as mission-critical third-party cloud services are vulnerable to such DOS attacks.

Malware: Establishing the persistence of malicious mechanisms within a well-chosen victim's infrastructure is a common threat, especially when it comes to Advanced Persistent Threat (APT) scenarios. For example, if the container engine authorization mechanism applied by KOSMoS is exploited in any way, an attacker is able to hide malicious applications in seemingly legitimate ecosystem modules such as container images (T1525 [32]). A malicious container successfully registered in the KOSMoS module registry can enable a wide range of exploitation techniques. In addition to the customer's on-premise infrastructure, the provider's KOSMoS Cloud system may also be affected.

SCADA System Attack: An attack on an SCADA system with encryption attacks can have catastrophic consequences for dependent systems and workflows [27]. While the infection process is similar to an attack on an end user device, the entire shop floor can be disrupted. If an customer's KOSMoS on-premise environment is affected by such encryption attacks, it will not be able to comply with the terms of the contract. Depending on the adaptation of the malicious application, the encryption of the non-ICS systems necessary for daily operations is also at stake at the same time.

B. Human Exposures

Social Engineering: One of the biggest threats to trusted cross-company relationships is social engineering. Understanding organizational procedures, policies used, and assessing the security awareness of key personnel will assist a malicious actor in planning and executing personalized phishing attacks [37].

Identity Spoofing: If a malicious actor has already gained access to a cloud-based environment section applied by KOSMoS Global, listing a cloud services users is easy to achieve (T1087.004 [32]). In addition to identifying human individuals associated with service users, poorly secured robotic or forgotten default and test accounts can also be discovered and exploited. Depending on the integration of the provider's identity and credential management, as well as the implementation of a system to improve data protection, discovered cloud system accounts are the ideal springboard for social engineering techniques and identity theft.

Misconfiguration: Since the configuration of complex distributed systems is prone to human error, meaningful logs and periodic audits support the use of robust KOSMoS On-premise environments.

C. Business Process Exposures

Faulty defined KOSMoS contract template: With deep knowledge of an organization's business processes, applied technical frameworks, certifications, and cross-company relationships, one is able to implement various malicious techniques that target a specific point in the process chain. If

a provider's private KOSMoS Cloud environment, e.g., Infrastructure as a Service (IaaS) details, is leaked, technical service interrelationships and hidden mechanisms can also be derived from the business contract specification. Depending on the security configuration of the system, technical information should be shielded by default if possible.

Service Provider manipulated Data: A service provider could issue an incorrect record release to the BC in order to mimic an KOSMoS-Contract violation originating from the customer, increasing costs. This type of malicious action requires access to the machine connectors execution environment in order to produce records with credible signatures. Therefore, regular checks of KOSMoS on-premise are recommended in order to prevent such behaviour in the first place.

Error Data Collection: Regardless of what type of sensors are used for a particular task, constant monitoring and comparison with expected data is advisable in any case. In the case of intentional manipulation of collected data, the damage can range from unusable ML models to breach of contract.

Contract Manipulation: Since the instantiated KOSMoS-Contract template contains parameters that are important for the execution of the smart contract, deviations from the on-premise configuration of a participating customer are not apparent. On the other hand, the consensus mechanism guarantees broad approval for contract changes.

D. Smart Contract Exposures

Non-Determinism: One of the key threats in *Hyperledger Fabric*-based BC platforms, is the non-determinism of smart contracts triggered by the use of a general purpose programming (Golang, Java, JavaScript) language instead of a domain specific programming language like Solidity that is specifically designed for distributed execution. Non-determinism can be triggered by programming language instructions (global variables, random numbers, retrieving the system timestamp, ...) and interaction with external services by the smart contract (stateful service, behavior of file system access, external libraries) [10]. While non-determinism does not tamper data within the BC, it affects the availability of the BC service implemented by the smart contract [38].

Input Validation / Error Handling: Two major threats that may be overlooked in the development of smart contracts are input validation and error handling, both of which have tremendous implications [10]. Both improper input validation and improper error handling can cause the smart contract to terminate or behave unexpectedly. Another side-effect of such poorly validated input is storing incorrect data in the BC, as mentioned by Ploder et. al. in [39], which potentially implies dramatic consequences to the KOSMoS billing system like overpricing a customer, underpayment of manufacturers respectively. Another attack specifically on the BC technology *Hyperledger* refers to the creation of malicious *Smart Contracts* [13]. Dependent on the targeted nodes countermeasure implementations, an *Smart Contract* attack may result in remote code execution using the frameworks *peer application*. Another exploit mentioned is the large-scale resource transfer

of node data which may be mitigated by the configurable *operation permission* system, restricting the participants potential actions in the first place.

External Services: Interaction with external services can pose a wide variety of risks, ranging from attacks to data confidentiality through sniffing attacks on communications between the BC and external services, attacks on identity management and identification of external services allowing an attacker to inject a malicious service into the infrastructure, and the availability of the external service in the first place [40], [41].

E. Use Case Exposures

For the discussion and assessment of risks to the KOSMoS framework, the *dynamic leasing* scenario was chosen, as depicted in Figure 3. By implementing a platform to track

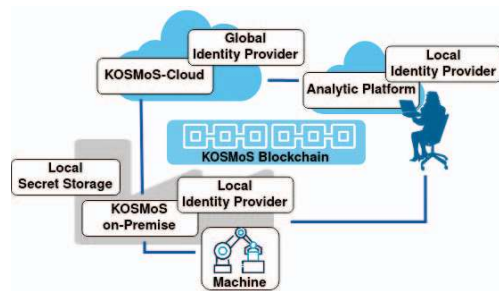


Fig. 3. High-Level Depiction of the KOSMoS Dynamic Leasing Scenario

changes to manufactured goods, a company is able to refine its product to meet specific customer or general market requirements. On the other hand, a customer can also benefit from various resulting ML models to realize predictive maintenance or quality proof of implementations. When the contract between provider and customer is extended to include an external service provider, e.g. the analysis platform, security concerns and the complexity of the overall system increase.

Infrastructure-specific Exposures: A DOS attack on the infrastructure of one or each of the three parties involved in the use case, e.g., provider, customer and data analyst, can hinder the real-time execution of the contracts. By infecting one contract partner with malware, the distribution of malicious code can be designed to spread to every other contract partner. By cloaking long-lived malicious applications and preventing Intrusion Detection System (IDS) mechanisms from capturing network traffic, bases of APT can be infiltrated. Another example is the communications between command and control servers and infected modules via hidden data in Domain Name System (DNS) packets. Dependent on the specific communication pattern within KOSMoS as for example the transmission of machine data to the BC API, Man in the Middle (MitM) attacks cannot be ruled out and should be mitigated by using message encryption by default. When configuring the BC with the use case in question, a variety of attacks regarding contract non-compliance are likely. Since access to the BC is based

on KOSMoS identities, the setup must also take into account compliance with applicable laws regarding the handling of PII. In addition, poorly defined *smart contracts* can cause new attack vectors. Because the KOSMoS ecosystem was designed on-premise as a highly generic infrastructure, configuration errors have dramatic consequences for the entire platform. A malicious actor may also deliberately use certain contexts in applied technologies to create an artificial attack surface.

Cross-Company Human-specific Factors: In inversion to multiple organizations, there is a broader attack surface for social engineering attacks, more verbose public accessible company information respectively. The greater the number of potential victims, the greater the likelihood that poorly protected or trained individuals will be exploited. There are multiple ways to achieve a malicious goal such as gaining access to a system by exploiting a subject's behavior, in any case, identity spoofing is a major threat to cross-company business models. In addition to physically gaining access to prohibited areas through the simple theft of an authorized key card, there is a high probability of getting lost in the digital mayhem with a seemingly legal account. The threat of malicious actors within an organization can almost never be ruled out. When a cross-company ecosystem like KOSMoS is exploited in disguise from the *inside*, the detection time of enterprise-specific anomaly detection or IDS systems can miss the insider attack.

Conditional Cross-Company Business Processes: Attacking the collected values directly allows for a variety of biasing scenarios that can impact the analytical process during model refinement [31]. An attack on BC execution, e.g., the automatic execution of smart contracts by the BC itself, can be directed at several targets. In addition to disrupting the processing of contract-related information, it is also possible to directly impact sensitive billing or management mechanisms. When manipulating machine usage records, an KOSMoS customer may attempt to reduce usage costs. Since the billing process is performed by the smart contract, subsequent anomaly detection is possible.

VI. CONCLUSION AND FUTURE WORK

In this paper, we presented an overview of the security threats to an industrial ecosystem based on BC technology. A BC-based platform, KOSMoS, with the main components in the cloud and on-premise at a manufacturer or service provider was described. Based on an industrial machine leasing use case, a threat analysis with an impact, risk, and vulnerability assessment was conducted. The novel security aspects of the KOSMoS platforms will be complementarity evaluated through additional use cases.

ACKNOWLEDGEMENT

The content was developed within the framework of the research project KOSMoS - "Collaborative Smart Contracting Platform for Digital Value Networks". It is funded by the Federal Ministry of Education and Research (BMBF) under reference number 02P17D026 and supervised by Projektträger Karlsruhe (PTKA).

REFERENCES

- [1] D. R. Bharadwaj, A. Bhattacharya, and M. Chakkaravarthy, "Cloud threat defense – a threat protection and security compliance solution," in *2018 IEEE International Conference on Cloud Computing in Emerging Markets (CCEM)*, 2018, pp. 95–99.
- [2] E. Jalalpour, M. Ghaznavi, D. Migault, S. Preda, M. Pourzandi, and R. Boutaba, "Dynamic security orchestration for cdn edge-servers," in *2018 4th IEEE Conference on Network Softwarization and Workshops (NetSoft)*, 2018, pp. 329–331.
- [3] H. Wang, Y. Wang, Z. Cao, Z. Li, and G. Xiong, "An overview of blockchain security analysis," in *Cyber Security*, X. Yun, W. Wen, B. Lang, H. Yan, L. Ding, J. Li, and Y. Zhou, Eds. Singapore: Springer Singapore, 2019, pp. 55–72.
- [4] S. Soni and B. Bhushan, "A comprehensive survey on blockchain: Working, security analysis, privacy threats and potential applications," in *2019 2nd International Conference on Intelligent Computing, Instrumentation and Control Technologies (ICICICT)*, vol. 1, 2019, pp. 922–926.
- [5] M. Saad, J. Spaulding, L. Njilla, C. Kamhoua, S. Shetty, D. Nyang, and D. Mohaisen, "Exploring the attack surface of blockchain: A comprehensive survey," *IEEE Communications Surveys Tutorials*, vol. 22, no. 3, pp. 1977–2008, 2020.
- [6] J. Sengupta, S. Ruj, and S. D. Bit, "A comprehensive survey on attacks, security issues and blockchain solutions for iot and iiot," *J. Neww. Comput. Appl.*, vol. 149, 2020. [Online]. Available: <https://doi.org/10.1016/j.jnca.2019.102481>
- [7] S. Wang, C. Wang, and Q. Hu, "Corking by forking: Vulnerability analysis of blockchain," in *IEEE INFOCOM 2019 - IEEE Conference on Computer Communications*, 2019, pp. 829–837.
- [8] D. K. Tosh, S. Shetty, X. Liang, C. A. Kamhoua, K. A. Kwiat, and L. Njilla, "Security implications of blockchain cloud with analysis of block withholding attack," in *2017 17th IEEE/ACM International Symposium on Cluster, Cloud and Grid Computing (CCGRID)*, 2017, pp. 458–467.
- [9] J. Liu and Z. Liu, "A survey on security verification of blockchain smart contracts," *IEEE Access*, vol. 7, pp. 77 894–77 904, 2019.
- [10] K. Yamashita, Y. Nomura, E. Zhou, B. Pi, and S. Jun, "Potential risks of hyperledger fabric smart contracts," in *2019 IEEE International Workshop on Blockchain Oriented Software Engineering (IWBOSE)*, 2019, pp. 1–10.
- [11] S. Kim and S. Ryu, "Analysis of blockchain smart contracts: Techniques and insights," in *2020 IEEE Secure Development (SecDev)*, 2020, pp. 65–73.
- [12] S. Tikhomirov, E. Voskresenskaya, I. Ivanitskiy, R. Takhaviev, E. Marchenko, and Y. Alexandrov, "Smartcheck: Static analysis of ethereum smart contracts," in *2018 IEEE/ACM 1st International Workshop on Emerging Trends in Software Engineering for Blockchain (WETSEB)*, 2018, pp. 9–16.
- [13] Z. Li, Y. Wang, S. Wen, and Y. Ding, "Evil chaincode: Apt attacks based on smart contract," in *Frontiers in Cyber Security*, G. Xu, K. Liang, and C. Su, Eds. Singapore: Springer Singapore, 2020, pp. 178–196.
- [14] J. Lockl, V. Schlatt, A. Schweizer, N. Urbach, and N. Harth, "Toward trust in internet of things ecosystems: Design principles for blockchain-based iot applications," *IEEE Transactions on Engineering Management*, vol. 67, no. 4, pp. 1256–1270, 2020.
- [15] W. Yáñez, R. Bahsoon, Y. Zhang, and R. Kazman, "Architecting internet of things systems with blockchain: A catalog of tactics," *ACM Transactions on Software Engineering and Methodology (TOSEM)*, vol. 30, no. 3, pp. 1–46, 2021.
- [16] H. Haddadpajouh, A. Dehghantanha, R. M. Parizi, M. Aledhari, and H. Karimipour, "A survey on internet of things security: Requirements, challenges, and solutions," *Internet of Things*, p. 100129, 2019. [Online]. Available: <http://www.sciencedirect.com/science/article/pii/S2542660519302288>
- [17] M. A. Khan and K. Salah, "Iot security: Review, blockchain solutions, and open challenges," *Future Generation Computer Systems*, vol. 82, pp. 395 – 411, 2018. [Online]. Available: <http://www.sciencedirect.com/science/article/pii/S0167739X17315765>
- [18] A. Jurcut, T. Niculcea, P. Ranawera, and N.-A. Le-Khac, "Security considerations for internet of things: A survey," *SN Computer Science*, vol. 1, no. 4, jun 2020.
- [19] S. Ali, T. Al Balushi, Z. Nadir, and O. K. Hussain, *Distributed Control Systems Security for CPS*. Cham: Springer International Publishing, 2018, pp. 141–160. [Online]. Available: https://doi.org/10.1007/978-3-319-75880-0_7
- [20] S. K. Jain and N. Kesswani, "Privacy threat model for iot," in *4th International Conference on Internet of Things and Connected Technologies (ICIoTCT)*, 2019, N. Nain and S. K. Vipparthi, Eds. Cham: Springer International Publishing, 2020, pp. 278–293.
- [21] M. Mohsin, Z. Anwar, G. Husari, E. Al-Shaer, and M. A. Rahman, "Iotsat: A formal framework for security analysis of the internet of things (iot)," in *2016 IEEE Conference on Communications and Network Security (CNS)*, 2016, pp. 180–188.
- [22] A. Humayed, J. Lin, F. Li, and B. Luo, "Cyber-physical systems security—a survey," *IEEE Internet of Things Journal*, vol. 4, no. 6, pp. 1802–1831, 2017.
- [23] V. Marquis, R. Ho, W. Rainey, M. Kimpel, J. Ghiorzi, W. Cricchi, and N. Bezzo, "Toward attack-resilient state estimation and control of autonomous cyber-physical systems," in *2018 Systems and Information Engineering Design Symposium (SIEDS)*, 2018, pp. 70–75.
- [24] F. Restuccia, S. D'Oro, and T. Melodia, "Securing the internet of things in the age of machine learning and software-defined networking," *IEEE Internet of Things Journal*, vol. 5, no. 6, pp. 4829–4842, 2018.
- [25] S. Dasari and V. Madipadga, "Aegis: A framework to detect compromised components in the supply chain of information technology infrastructure," in *2020 International Workshop on Big Data and Information Security (IWBIS)*, 2020, pp. 159–164.
- [26] J. M. McGinthy and A. J. Michaels, "Secure industrial internet of things critical infrastructure node design," *IEEE Internet of Things Journal*, vol. 6, no. 5, pp. 8021–8037, 2019.
- [27] U. Javed Butt, M. Abbod, A. Lors, H. Jahankhani, A. Jamal, and A. Kumar, "Ransomware threat and its impact on scada," in *2019 IEEE 12th International Conference on Global Security, Safety and Sustainability (ICGS3)*, 2019, pp. 205–212.
- [28] "Harbor," <https://goharbor.io/>, accessed: 02.06.2021.
- [29] "Keycloak," <https://www.keycloak.org/>, accessed: 02.06.2021.
- [30] "Hashicorp vault," <https://www.vaultproject.io/>, accessed: 02.06.2021.
- [31] M. Xue, C. Yuan, H. Wu, Y. Zhang, and W. Liu, "Machine learning security: Threats, countermeasures, and evaluations," *IEEE Access*, vol. 8, pp. 74 720–74 742, 2020.
- [32] "MITRE att&ck," <https://attack.mitre.org/>, accessed: 2020-11-30.
- [33] R. Kwon, T. Ashley, J. Castleberry, P. Mckenzie, and S. N. Gupta Gouriseti, "Cyber threat dictionary using mitre att ck matrix and nist cybersecurity framework mapping," in *2020 Resilience Week (RWS)*, 2020, pp. 106–112.
- [34] R. Al-Shaer, J. M. Spring, and E. Christou, "Learning the associations of mitre att ck adversarial techniques," in *2020 IEEE Conference on Communications and Network Security (CNS)*, 2020, pp. 1–9.
- [35] J. Straub, "Modeling attack, defense and threat trees and the cyber kill chain, att ck and stride frameworks as blackboard architecture networks," in *2020 IEEE International Conference on Smart Cloud (SmartCloud)*, 2020, pp. 148–153.
- [36] D. Deogun, D. Johnsson, and D. Sawano, *Secure By Design*. Manning Publications, 2019. [Online]. Available: <https://books.google.de/books?id=jDkxtAEACAAJ>
- [37] C. Hadnagy, *Social engineering: The science of human hacking*. John Wiley & Sons, 2018.
- [38] E. Androulaki, A. Barger, V. Bortnikov, C. Cachin, K. Christidis, A. De Caro, D. Enyeart, C. Ferris, G. Laventman, Y. Manevich *et al.*, "Hyperledger fabric: a distributed operating system for permissioned blockchains," in *Proceedings of the thirteenth EuroSys conference*, 2018, pp. 1–15.
- [39] C. Ploder, T. Spiess, R. Bernsteiner, T. Dilger, and R. Weichelt, "A risk analysis on blockchain technology usage for electronic health records," *Cloud Computing and Data Science*, pp. 1–16, 2021.
- [40] D. Welte, A. Sikora, D. Schönle, J. Stodt, and C. Reich, "Blockchain at the shop floor for maintenance," in *2020 International Conference on Cyber-Enabled Distributed Computing and Knowledge Discovery (CyberC)*. IEEE, 2020, pp. 15–22.
- [41] J. Stodt, D. Schönle, C. Reich, F. Ghovanlooy Ghajar, D. Welte, and A. Sikora, "Security audit of a blockchain-based industrial application platform," *Algorithms*, vol. 14, no. 4, 2021. [Online]. Available: <https://www.mdpi.com/1999-4893/14/4/121>